ADR-004 — Priorizar Segurança como Característica Arquitetural (rev1)

Status: Proposto | Data: 20/10/2026 | Autor(es): Equipe ___

Revisa: ADR-004 de 13/10/2026 (versão original preservada no histórico do repositório).

Requisitos/restrições relacionados: Seção 3 (acesso apenas por usuários cadastrados); REQ01–REQ04 (cadastro, recuperação de senha, login, logout); REQ05–REQ06 (faturamento e pagamento); REQ08 (URL informada pelo usuário); REQ12–REQ15 (acesso a registros e arquivos); Apêndice A (CPF, OAB, senha); D1; LGPD; ADR-007; ADR-008; ADR-010; ADR-012.

Contexto

Único atributo de qualidade declarado no documento de requisitos (Seção 3). O sistema trata dados pessoais (CPF, OAB, senha), dados de faturamento e evidências com valor legal, sujeitos à LGPD. Além disso, o servidor abre URLs informadas pelo usuário (REQ08), o que expõe a rede interna a ataques de SSRF se a navegação não for isolada.

Decisão

Tratar segurança como driver arquitetural, com as seguintes medidas:

- **Autenticação centralizada no gateway:** access token JWT de curta duração (15 min) e refresh token opaco armazenado no servidor, rotacionado a cada uso e revogável — o logout (REQ04) revoga a sessão; tokens em cookie HttpOnly, Secure e SameSite.
- **Senhas** com Argon2id. **Recuperação de senha** (REQ02): token aleatório de uso único, válido por 30 minutos, armazenado como hash, com resposta idêntica para email existente ou não.
- **Rate limiting** e atraso progressivo em login e recuperação de senha; TLS obrigatório.
- **Autorização por dono do recurso** em todo acesso a registros, relatórios e ZIP (contra IDOR); downloads por URL pré-assinada de curta duração (ADR-008). RBAC por perfil apenas onde houver diferença de permissão (D1: advogado, usuário comum e, futuramente, empresa).
- **Criptografia em repouso:** CPF e dados de faturamento com AES-256-GCM, mais índice cego (HMAC) para verificar unicidade do CPF sem decifrá-lo; mídias com criptografia no storage (ADR-008).
- **Proteção contra SSRF:** o navegador de captura sai para a internet apenas por um proxy de egress em rede isolada (ADR-012), que bloqueia IPs privados, loopback, link-local e endpoints de metadados, revalidando após a resolução DNS e a cada redirecionamento; somente http/https.
- Webhooks de pagamento com assinatura validada (ADR-010); segredos fora do código (ADR-012); trilha de acesso às evidências (ADR-002).
- **LGPD:** dados cadastrais excluíveis/anonimizáveis mediante solicitação; evidências retidas pelo prazo definido nos termos de uso, com base no exercício regular de direitos (art. 7º, VI) — a validar juridicamente; após o prazo, exclusão.

Alternativas Consideradas

1. Autenticação distribuída por serviço — rejeitada: amplia a superfície de ataque e duplica a política de acesso.
2. JWT stateless sem revogação (versão anterior, implícita) — rejeitado: o logout não invalidaria o token até a expiração.
3. Criptografia apenas em trânsito — rejeitada: dados sensíveis em repouso ficariam expostos.
4. Provedor de identidade externo (SSO) — rejeitado na v1: acopla o cadastro próprio (REQ01) a um terceiro desde o início.
5. Navegador de captura na mesma rede dos serviços — rejeitado: qualquer usuário poderia alcançar banco, storage e mensageria internos (SSRF).

Justificativa

- Ponto único de entrada com política centralizada continua sendo a tática de melhor custo/benefício no estilo escolhido (ADR-001).
- Refresh token revogável atende ao logout real exigido pelo REQ04 mantendo a validação do access token barata no gateway.
- Os requisitos não diferenciam funcionalidades por perfil; o risco dominante é um usuário acessar registros de outro, por isso a autorização por dono do recurso é a medida principal.
- A navegação de URLs arbitrárias é a maior superfície de ataque específica do Veridit; isolá-la na rede é mais robusto que validar URLs apenas na aplicação.
- Separar dados cadastrais (excluíveis) de evidências (retidas com base legal) concilia a LGPD com a imutabilidade exigida pela integridade (ADR-002, ADR-008).

Cenários de Qualidade (medida de resposta)

- Estímulo: usuário autenticado altera o id na URL para acessar registro de outro usuário. Resposta: acesso negado e evento auditado. Medida: 100% bloqueado, verificado por testes automatizados.
- Estímulo: usuário informa como URL de captura um endereço interno (ex.: 169.254.169.254 ou 10.0.0.5). Resposta: conexão recusada pelo proxy de egress. Medida: 100% bloqueado.
- Estímulo: tentativas de senha em massa. Resposta: após 5 falhas em 15 minutos, atraso progressivo e alerta. Medida: no máximo 20 tentativas por hora por conta.

Consequências

Positivas: superfície de ataque reduzida; logout efetivo; conformidade com a LGPD; acessos auditáveis; rede interna protegida contra SSRF.

Negativas: latência adicional no gateway; gestão de chaves e segredos; armazenamento de sessões de refresh; proxy de egress como componente adicional.

Mitigações: validação local do access token (sem consulta a cada requisição); cofre de segredos com rotação de chaves; testes automatizados de autorização e de SSRF no CI.

Alterações em relação à versão anterior

- Logout efetivo com refresh token revogável; recuperação de senha segura; rate limiting.
- Proteção contra SSRF na captura (proxy de egress em rede isolada).
- Autorização por dono do recurso priorizada sobre RBAC; índice cego para o CPF.
- Política LGPD x retenção de evidências; cenários mensuráveis.